



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Gitea CVE-2026-60004 Remote Code Execution KEV Daily Priority Update

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-08-29
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Gitea CVE-2026-60004 Remote Code Execution KEV Daily Priority Update - CVE / Vulnerability Threat Intelligence Report

Published: 2026-08-29 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Gitea CVE-2026-60004 Remote Code Execution KEV Daily Priority Update

1. Executive Summary

Gitea CVE-2026-60004 Remote Code Execution KEV Daily Priority Update is prioritized for 2026-08-29 because public reporting indicates active exploitation or immediate defender action windows. The exposure matters because the affected product sits close to authentication, source-code management, remote access, or operational workflows where compromise can become credential theft, web shell deployment, or downstream supply-chain abuse.

Lost Boys Cyber assesses this item as CRITICAL priority for organizations with exposed or internet-reachable Gitea self-hosted Git service deployments. The fastest defensive path is asset inventory, vendor patch validation, focused log review for exploitation indicators, and temporary isolation of high-risk public interfaces where patching cannot complete immediately.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-60004
Product / Component	Gitea self-hosted Git service
Weakness	Code injection/RCE path involving repository-controlled content and Git hook execution through diffpatch handling, per public reporting.
Severity	Critical daily priority
Affected Versions	Validate against vendor advisory and local asset inventory
Fixed Versions	Upgrade to Gitea 1.27.1 or later and review repository write-access exposure.
Disclosure / Update Window	Prioritized in the 24-72 hour daily intelligence window ending 2026-08-29
Exploitation Status	Multiple public sources report CISA KEV listing and active exploitation, including miner-like payload delivery in at least one reported attack path.

3. Source Review & Confidence

Source	Contribution	Confidence
The Hacker News	Reported active exploitation and miner-like payload context.	High
Help Net Security	Reported Gitea diffpatch/Git hook abuse path.	High
runZero	Asset-finding and exposure context; notes KEV addition.	Medium
SecurityWeek	Additional corroboration of CISA exploited-vulnerability warning.	Medium

Confidence is bounded by daily automation and public-source availability. Vendor advisories and CISA/NVD records should be treated as the authority for final version ranges and emergency maintenance language.

4. Vulnerability Details

The vulnerability should be treated as an externally actionable exposure when the affected service is reachable by untrusted users or by lower-trust internal users. Public reporting indicates a path from application flaw to code execution or attacker-controlled behavior; exploitation details should not be assumed beyond the cited research until verified against canonical vendor guidance.

5. Attack Scenarios

- Internet-facing instance is exploited before patching, resulting in command execution, web shell deployment, or service-account compromise.
- Authenticated or repository-write capable attacker abuses the flaw to execute code in a development or appliance context.
- Compromised service identity is used to pivot into secrets, source code, CI/CD pipelines, or adjacent management networks.

6. Threat Landscape & Exploitation Status

Multiple public sources report CISA KEV listing and active exploitation, including miner-like payload delivery in at least one reported attack path. This report does not attribute exploitation to a named actor unless a cited source explicitly does so. Treat all unpatched exposed systems as urgent triage candidates.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
Internet-facing affected service	Highest exploitation likelihood and easiest attacker discovery path.
Internal high-value workflow	Developer, remote-access, and appliance systems often hold credentials and trusted network paths.
Patched with monitoring	Risk is reduced but post-exploitation review remains necessary where exposure existed before remediation.

8. Mitigation and Workarounds

Priority	Owner	Action
Critical	Infrastructure / Platform	Inventory affected products, confirm external exposure, and apply vendor fixed versions.
High	SOC	Review logs for suspicious command execution, new admin users, web shell patterns, and unusual outbound traffic.
High	Identity / IAM	Rotate secrets used by the affected service if exploitation cannot be ruled out.
Medium	Risk / Client Delivery	Notify system owners and track remediation evidence by asset.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Suspicious child process from product service account	EDR DeviceProcessEvents	Identify application-to-shell execution.
Unexpected outbound traffic from product host	EDR/Proxy DeviceNetworkEvents	Identify payload retrieval or C2 after exploitation.
New web files or hook/script artifacts	File telemetry	Find persistence or post-exploitation tooling.

9.2. Sigma / Detection Rule

```

title: Gitea CVE-2026-60004 RCE Suspicious Post-Exploitation Behavior
status: experimental
logsource:
  product: linux
  category: process_creation
detection:
  selection_shell:
    Image|endswith:
      - '/sh'
      - '/bash'
      - '/curl'
      - '/wget'
  selection_context:
    CommandLine|contains:
      - 'Gitea'
      - 'CVE-2026-60004'
  condition: selection_shell or selection_context
level: high

```

9.3. Hunt Query

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where ProcessCommandLine has_any ('CVE-2026-60004', 'curl ', 'wget ', 'bash -c', 'sh -c')
| where InitiatingProcessAccountName has_any ('gitea', 'nsroot', 'www-data', 'nginx', 'apache', 'svc')
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessAccountName, FileName, ProcessCommandLine

```

10. Threat Hunting

10.1. Hunt Hypothesis

An attacker exploited an affected public-facing service and launched shell tooling or created persistence before patching completed.

10.2. Hunt Query

```

DeviceNetworkEvents
| where Timestamp > ago(14d)
| where InitiatingProcessCommandLine has_any ('curl', 'wget', 'powershell', 'bash', 'sh')
| summarize count(), min(Timestamp), max(Timestamp), make_set(RemoteUrl, 20) by DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine
| order by count_desc

```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
-----------	------	----------------------

T1190	Exploit Public-Facing Application	Public reporting and defensive analysis map the activity to this behavior.
T1059.004	Unix Shell	Public reporting and defensive analysis map the activity to this behavior.
T1552	Unsecured Credentials	Public reporting and defensive analysis map the activity to this behavior.

12. Validation / Lab Testing

No exploit reproduction was performed during this scheduled production run. Validation completed: source triage, exposure-model analysis, detection/hunt authoring, PDF render QA, and OpenCTI upload attempt.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Asset owner	Patch or isolate affected systems immediately.
High	SOC	Run the included hunts across the exposure window.
High	Identity	Rotate exposed service secrets where compromise cannot be excluded.
Medium	Governance	Record evidence of patch and monitoring completion.

14. References

- [The Hacker News](<https://thehackernews.com/2026/08/critical-gitea-rce-actively-exploited.html>) — Reported active exploitation and miner-like payload context.
- [Help Net Security](<https://www.helpnetsecurity.com/2026/08/26/gitea-cve-2026-60004-exploited-in-the-wild/>) — Reported Gitea diffpatch/Git hook abuse path.
- [runZero](<https://www.runzero.com/blog/gitea/>) — Asset-finding and exposure context; notes KEV addition.
- [SecurityWeek](<https://www.securityweek.com/cisa-warns-of-exploited-gitea-vulnerability/>) — Additional corroboration of CISA exploited-vulnerability warning.